
MÓDULO A.1: ROLES, PERMISOS Y SEGURIDAD (RBAC)

Objetivo: Establecer una matriz de control de acceso basada en roles (Role-Based Access Control - RBAC) que defina qué puede hacer cada usuario, garantizando la seguridad, la trazabilidad inmutable y el cumplimiento de la Ley Federal de Protección de Datos Personales en Posesión de Particulares (LFPDPPP).

1. Alcance y Principios Transversales

1.1 Gobernanza de Datos

La administración de los Datos Personales de los Usuarios Médicos será responsabilidad del Titular, conforme a los principios de licitud, consentimiento, información, calidad, finalidad, lealtad, proporcionalidad y responsabilidad contenidos en la ley.

1.2 Jerarquía y Control

El sistema opera bajo una jerarquía estricta donde el **Súper Administrador de Plataforma** tiene control universal, y el **Súper Administrador de Perfil** (médico, hospital, etc.) tiene la facultad de delegar o revocar permisos a sus operadores,.

2. Roles Internos de la Plataforma (México Médico)

Estos roles gestionan la operación del sistema central y tienen acceso a paneles de control internos,.

Rol Interno	Descripción y Semblanza	Facultades Clave
Administrador Principal / Súper Administrador	Máxima autoridad de la plataforma. Solo habrá dos cuentas (una activa, una de respaldo),.	Acceso universal a todas las funciones y secciones,. Crea, modifica o elimina cualquier operador. Autoriza cambios críticos, define planes y precios,.
Operador Administrativo Económico	Maneja la parte financiera de la plataforma (cobranza/facturación).	Accede a datos económicos de la plataforma y extrae reportes. Acredita pagos manuales,. Envía notificación al Súper Administrador tras acreditar pagos manuales,.

Operador de Asistencia Técnica	Brinda soporte a usuarios y opera el mantenimiento del sistema.	Asiste a usuarios en la recuperación de credenciales. Resuelve incidencias técnicas reportadas por usuarios.
Operador de Verificación y Clasificación	Revisa y clasifica perfiles.	Valida la documentación y cédulas de perfiles nuevos o con cambios importantes antes de su publicación. Gestiona la vinculación a grupos médicos y padecimientos.
Operador de Mercadotecnia / Difusión	Gestiona los módulos de contenido público y promoción.	Crea, edita y publica contenido en el blog/artículos,. Diseña paquetes y promociones.
Operador de Citas Global	Brinda servicio de agendamiento de citas en nombre de médicos/clínicas que contratan este servicio.	Accede a las agendas que le son facultadas, puede crear, modificar o cancelar citas,. Opera también por llamada/chat.

3. Roles Base del Cliente (Perfiles)

Todos los perfiles profesionales (médicos, hospitales, laboratorios) tienen esta estructura jerárquica:

Rol del Cliente	Alcance	Lógica de Permisos
Administrador Principal / Titular	Control total sobre el perfil.	Define roles de operadores, tiene acceso exclusivo a funciones No Delegables (Ej. diagnóstico, recetas),,.
Operador de Perfil (Asistente)	Permisos limitados y delegados.	Acceso a funciones Delegables (ej. agenda, datos básicos no sensibles, facturación con autorización). Sus acciones dejan trazabilidad obligatoria.

4. Reglas Transversales de Permisos (RBAC)

El control de acceso se rige por la diferenciación entre información clínica sensible y funciones administrativas, asegurando la **trazabilidad**.

4.1 Principio de No Delegabilidad

Las siguientes acciones **NUNCA** podrán ser delegadas a un Operador, ni siquiera con autorización del Administrador Principal,,:

- **Diagnóstico clínico** (registrar o editar).
- **Notas de evolución / seguimiento.**
- **Creación/Edición/Firma de Recetas,.**
- **Creación/Edición de Consentimiento Informado,.**
- **Creación/Edición de Documentos Hospitalarios.**

4.2 Excepciones para Reimpresión

Los operadores sí pueden **reimprimir** (generar una copia) de Recetas y Consentimientos Informados ya emitidos, pero esta acción debe disparar una **notificación automática** al Médico Administrador y quedar registrada en bitácora,,.

4.3 Delegación Condicionada

La **Facturación a pacientes** y la **Captura de datos básicos no sensibles** (peso, talla, PA, etc.) son funciones delegables, pero requieren la **autorización explícita** del Médico Administrador,.

5. Trazabilidad y Seguridad de Datos

5.1 Bitácora Inmutable

Toda acción crítica realizada por cualquier rol (interno o cliente) debe registrarse en una **bitácora inmutable (solo lectura)**,.

El registro mínimo incluye,:

- **Usuario/Rol** que realizó la acción.
- **Fecha/Hora** de la acción (timestamp).
- **Acción** realizada (ej. EDIT, CREATE, REPRINT, LOGIN_FAIL).
- **Módulo** afectado (Agenda, Facturación, Expediente).
- **Valor antes y después** (en caso de edición).

5.2 Autenticación Reforzada

El sistema soporta múltiples métodos de acceso seguro:

- **Autenticación Tradicional:** Correo electrónico y contraseña.
- **Doble Factor de Autenticación (2FA):** Disponible para todos los perfiles reclamados.
- **Biometría / Passkeys (WebAuthn):** Disponible de manera **opcional** para administradores y operadores,. Esta opción nunca será obligatoria para garantizar la compatibilidad de dispositivos.

5.3 Flujo de Gestión de Credenciales

El administrador del perfil puede crear operadores y **revocar acceso** en cualquier momento. La gestión de operadores se realiza en un doble acceso: **Seguridad y Acceso** (vista de control total) y **Agenda** (vista funcional para operadores de citas),.

6. Integración de Cumplimiento Legal

6.1 Responsable Sanitario

Para clínicas, hospitales y laboratorios, el flujo de **apertura/reclamo de perfil** incluye un paso forzoso para el nombramiento del **Responsable Sanitario**, quien se convierte automáticamente en el Administrador Principal del perfil,.

6.2 Lógica de Gating (Roles vs. Planes)

Las funciones, alertas y permisos de cada rol están condicionados por el **Plan Contratado** (Gratis, Básico, Estándar, Óptimo, Profesional). Si un perfil desciende de plan, las funciones se **congelan** y se muestran con el mensaje "Disponible al contratar un plan superior",.

FIN DEL MÓDULO A.1